

MÓDULO 1
Seguridad Informática
y Criptografía
Ciberseguridad

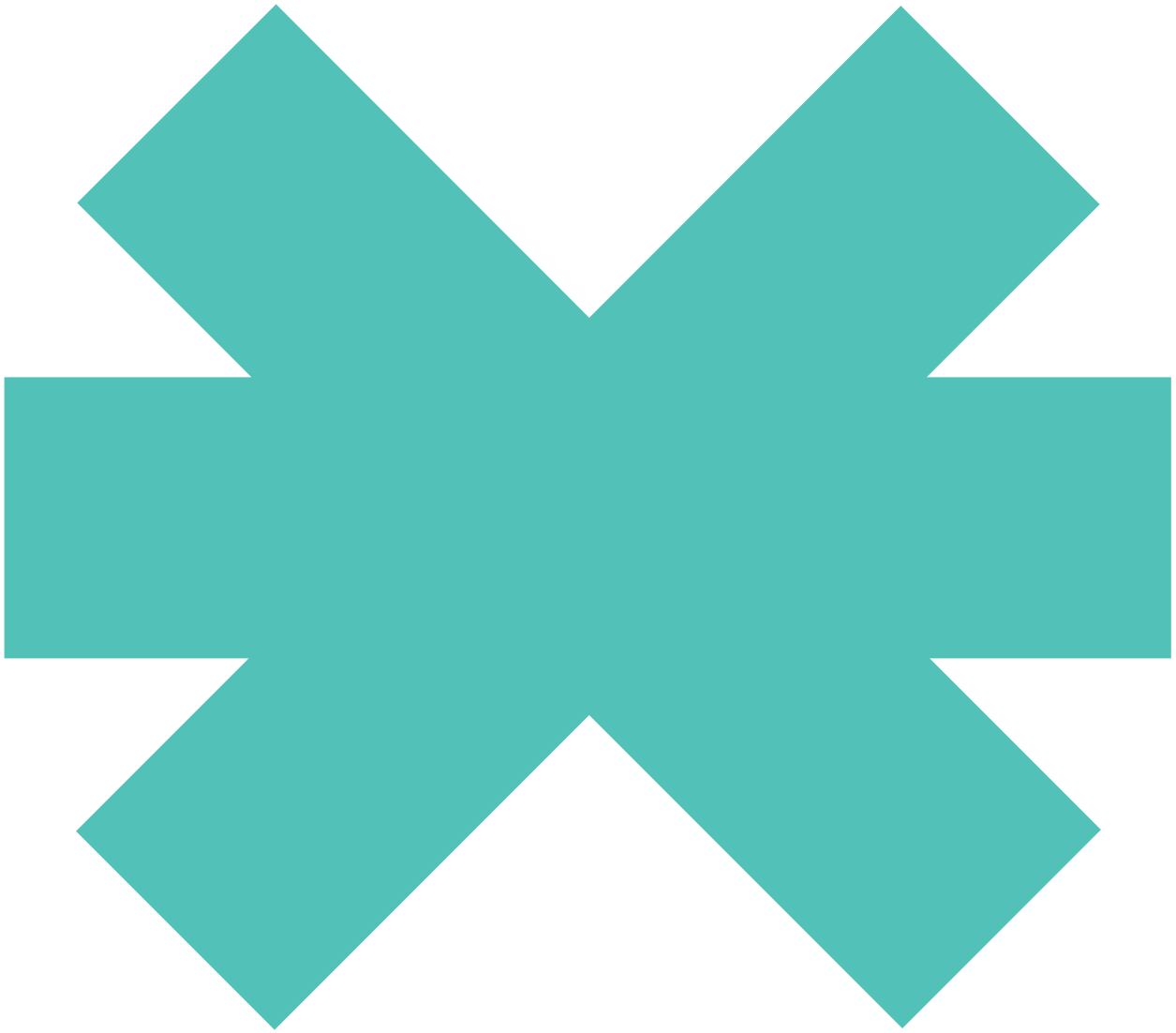
2

Amenazas y vulnerabilidades



New
Technology
School

Tokio.



2 Amenazas y vulnerabilidades

Sumario

2.1	Conceptos generales de vulnerabilidades, amenazas y riesgos	30
2.2	Ciberdelincuentes y <i>hackers</i>	33
2.3	Ciclo de vida de un ataque	34
2.4	Ataques más comunes	35

2.1 Conceptos generales de vulnerabilidades, amenazas y riesgos

La seguridad de los activos de una compañía ha de representar uno de sus principales objetivos y no solo debe abordarse por medio de los equipos de seguridad, sino que cualquier persona que forme parte de esta, desde el director/a financiero hasta quien se encuentre detrás del teléfono, ha de contar con una concienciación mínima, bien para colaborar con la organización, bien para evitar recibir el ataque. Aunque parezca un gran tópico, el mayor riesgo de una compañía suele residir en el eslabón más débil, que normalmente se sitúa entre el teclado y la silla...

Partiendo de lo anterior, para llevar a cabo mejores análisis a la hora de disminuir las vulnerabilidades de la compañía, teniendo en cuenta tanto sus riesgos como las amenazas, resulta necesario distinguir claramente tres conceptos:

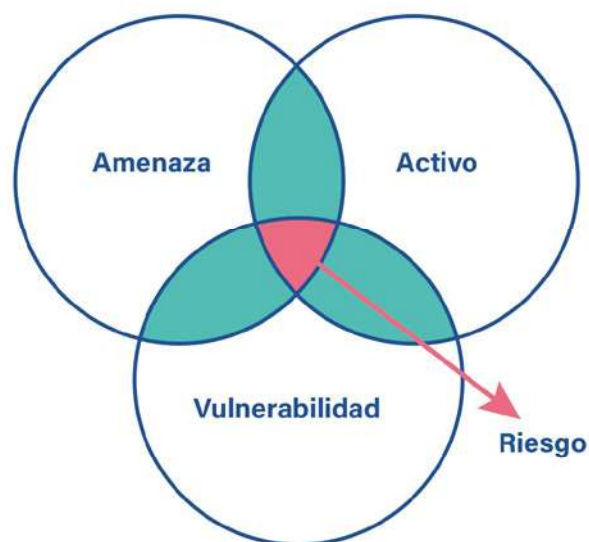


Figura 16. Relación entre amenaza, activos (sistemas de la información) y vulnerabilidades

- **Vulnerabilidad.** Debilidad que permite que el sistema o la aplicación reciban un ataque y/o un daño, es decir, que pueda ser aprovechada por una amenaza. Este concepto suele relacionarse con la tríada CIA, es decir, la confidencialidad, la integridad y la disponibilidad.
- **Amenaza.** Posibilidad de que un sistema sea atacado, es decir, de que alguien se aproveche de una vulnerabilidad ocasionada por un evento físico o natural tanto voluntario como involuntario. Entre las amenazas más importantes a las que puede permanecer expuesta una compañía, podemos mencionar el robo de identidad, código malicioso, negligencia, etc.

Cuando una amenaza aprovecha una vulnerabilidad, nos encontramos ante un **incidente de seguridad**, que implica la explotación de una o varias vulnerabilidades.

- **Riesgo.** Se define como la probabilidad de que ocurra un incidente de seguridad. Suele concebirse como la combinación entre la posibilidad de que se produzca un suceso y sus consecuencias. Los riesgos a los que pueden permanecer expuestos los activos y los sistemas de información son:

- Los **ataques** generados por ciberdelincuentes.
- Los **errores humanos** derivados de descuidos o de la falta de concienciación.
- Los **desastres naturales**, como inundaciones, terremotos, incendios, etc.
- Las **circunstancias extraordinarias**, como caídas de tensión, ataques terroristas, etc.

En base a estos conceptos, cabe subrayar que las amenazas y las vulnerabilidades pueden proceder de diversas fuentes, como *hackers*, *malware*, errores humanos, desastres naturales e incluso factores internos como una mala configuración de seguridad.

Principales fuentes de amenazas

Dentro del área de la ciberseguridad, encontramos diversas amenazas que pueden comprometer la seguridad e integridad de los sistemas y la información. A continuación, describiremos algunas de las principales, así como sus fuentes más habituales; no obstante, debemos tener en cuenta que las amenazas evolucionan constantemente, lo que exige permanecer al día sobre las nuevas técnicas utilizadas por los ciberdelincuentes.

- **Malware.** Cualquier tipo de código o *software* que persigue objetivos maliciosos. Resulta esencial identificar los diferentes tipos de *malware* ya que, por desconocimiento, hoy en día suele utilizarse el término virus para aludir a cualquier elemento malicioso; sin embargo, existen infinidad de posibles ataques cuya denominación genérica es *malware* y cuya tipología abordaremos un poco más adelante.



Figura 17. Amenaza de *malware*. Fuente: Freepik.com

- **Ingeniería social.** Manipulación psicológica de las personas para obtener información confidencial. Recurre a técnicas de persuasión y engaño para recabar contraseñas, datos de acceso o información privilegiada. Normalmente, a tal fin, los ciberdelincuentes suelen hacerse pasar por miembros de una empresa conocida y legítima para ganarse la confianza de sus víctimas.

- **Amenazas Persistentes Avanzadas (APT).** Se trata de ataques dirigidos y muy sofisticados que buscan acceder a los sistemas y comprometerlos de forma prolongada con el objeto de robar información sensible o causar daños a una compañía. Dada su complejidad, detectar y mitigar las APT suele representar un auténtico desafío.
- **Botnets.** Redes de dispositivos comprometidos y controlados por un ciberdelincuente conocido como *botmaster*. Los equipos que forman parte de la red se encuentran infectados y ejecutan programas de forma automática y autónoma, es decir, sin el conocimiento del propietario del ordenador; asimismo, el control que ejerce el *botmaster* sobre ellos le permite ejecutar ataques más sofisticados.
- **Páginas web y redes sociales.** A menudo, tanto en redes sociales como en determinadas páginas web no se mantiene ningún control sobre la información o se cuenta con una seguridad deficiente, lo que permite a los ciberdelincuentes atacar estas fuentes para obtener información confidencial de sus usuarios y usuarias o bien dañar la reputación de una empresa u organización mediante publicaciones masivas.

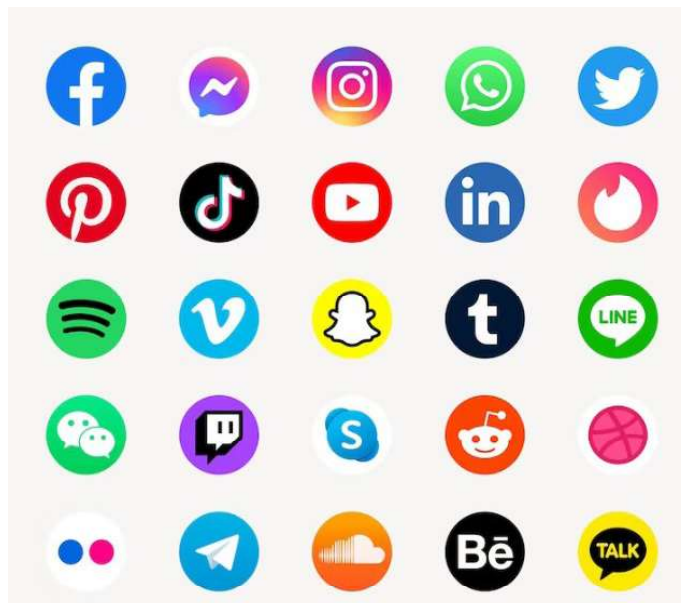


Figura 18. Principales redes sociales. Fuente: Freepik.com

- **Servicios en la nube.** Resulta necesario exigir a los proveedores de servicios en la nube los mismos criterios de seguridad que se requieren en la organización o compañía. De lo contrario, los ciberdelincuentes pueden aprovechar la coyuntura para acceder de forma no autorizada, aprovechar vulnerabilidades de la infraestructura o detectar las brechas de seguridad de dichos proveedores.

2.2 Ciberdelincuentes y *hackers*

Gran parte de la población asocia los términos ciberdelincuente y *hacker* a la misma realidad, considerando que se trata de personas con objetivos maliciosos que buscan causar daños a través de la red. Sin embargo, existen diferencias muy significativas entre ambas figuras.

Denominamos **ciberdelincuente** a aquella **persona que se involucra en actividades ilegales en el ámbito cibernético**. Los objetivos que persigue suelen consistir en causar daños, obtener beneficios económicos de forma ilícita o cometer actos delictivos en línea como el robo de datos, el fraude, la extorsión o la distribución de *malware*, entre otros.

En cambio, el término **hacker** posee diferentes connotaciones según el contexto. La RAE lo define como “Persona con grandes habilidades en el manejo de computadoras que investiga un sistema informático para avisar de los fallos y desarrollar técnicas de mejora” (Real Academia Española, 2014, definición 2) . Por tanto, se trata de aquella **persona que trata de solventar o informar sobre los problemas de seguridad** detectados en servicios informáticos, plataformas, herramientas o *software*.

Ahora bien, podemos distinguir **varios tipos de hackers** en función de sus intereses:

- **White hat.** Este tipo de *hackers* se rigen por las normas regulatorias del país y su objetivo es identificar las vulnerabilidades de la compañía para que, posteriormente, esta las solucione.
- **Black hat.** Expertos en seguridad cuyo objetivo es robar datos o destruir información para obtener algo a cambio, principalmente dinero, o bien dañar la reputación de la compañía atacada. Por supuesto, este tipo de ataques son ilegales.
- **Blue hat.** Subtipo de los **black hat**, también conocidos como “vengadores”, ya que no persiguen lucrarse u obtener fama, sino causar daños a una compañía o empresario a modo de venganza personal.
- **Grey hat.** Su objetivo es obtener una experiencia divertida mientras testean a las compañías y, una vez identifican alguna vulnerabilidad, pueden comunicarla de manera altruista o esperando una recompensa a cambio.
- **Orange hat.** Subtipo de **grey hat**, también conocidos como *hacktivistas*, ya que usan sus conocimientos en ciberseguridad con fines políticos o ideológicos.



Figura 19. Diferentes tipos de *hackers*

2.3 Ciclo de vida de un ataque

Una vez identificadas las diversas fuentes de amenazas a las que nos podemos enfrentar, así como las diferencias que existen entre un ciberdelincuente y un *hacker*, debemos adentrarnos en los ciberataques.

Podemos definir un ciberataque como el **acto malicioso** llevado a cabo por los ciberdelinquentes con la finalidad de **comprometer la seguridad de los sistemas informáticos, redes, dispositivos o servicios en línea**. Tales ataques pueden adoptar diversas formas y recurrir a distintas técnicas y entre sus principales objetivos se encuentran obtener acceso no autorizado, robar información confidencial, interrumpir operaciones normales o causar daño a individuos, organizaciones o infraestructuras.

Los ataques informáticos se desarrollan en **siete etapas** que se corresponden con su ciclo de vida:

- **Reconocimiento.** En esta fase, el atacante reúne información sobre su objetivo, por ejemplo, identificando sistemas, redes o potenciales vulnerabilidades. En este sentido, puede recurrir a técnicas como búsqueda de información en línea, escaneo de puertos o envío de correos electrónicos de *phishing* para obtener información adicional. Asimismo, de cara al reconocimiento, es habitual utilizar las técnicas de **footprinting** y *fingerprinting*: mientras que la primera consiste en la **recopilación de información a través de canales de acceso público** como redes sociales, foros, búsquedas en internet, etc., para el **fingerprinting** se recurre a **técnicas invasivas** como el escaneo de puertos en escucha con el objeto de detectar vulnerabilidades.
- **Intrusión.** Una vez reunida la información necesaria, el atacante trata de ingresar a los sistemas o redes objetivo intentando aprovechar vulnerabilidades conocidas, utilizando credenciales robadas o llevando a cabo ataques de fuerza bruta para obtener un acceso no autorizado.
- **Explotación.** En esta fase, el atacante busca explotar las vulnerabilidades identificadas en el sistema o red comprometida recurriendo a técnicas como inyección de código, ejecución remota de comandos o explotación de brechas de seguridad para obtener un mayor control sobre el objetivo.
- **Escalada de privilegios.** Cuando el atacante ha obtenido un nivel de acceso inicial, intenta ampliar sus privilegios dentro del sistema o red comprometida tratando de obtener permisos o credenciales de administrador para acceder a información o realizar acciones que, normalmente, se encuentran restringidas.
- **Movimiento lateral.** En esta fase, el atacante se mueve a través de la red comprometida buscando expandir su presencia y acceder a otros sistemas o dispositivos. En este sentido, utiliza técnicas como el escalamiento de privilegios, la propagación de *malware* o credenciales robadas para moverse de un sistema a otro.
- **Mantenimiento del acceso.** Una vez asegurado su acceso y su control de la red, el atacante tratará de mantenerlos de forma permanente instalando herramientas de persistencia, creando cuentas de usuario falsas o estableciendo puntos de entrada alternativos para asegurarse de que podrá acceder nuevamente en el futuro (puertas traseras).
- **Exfiltración de datos.** Finalmente, el atacante busca robar, filtrar o transferir datos sensibles o valiosos del sistema o red comprometida. Así, puede copiar archivos, extraer información confidencial o utilizar técnicas encubiertas para enviar datos fuera de la red comprometida sin que sean detectados.

2.4 Ataques más comunes

Como ya sabemos, un ataque es un **intento malicioso de comprometer la seguridad de una red informática**. Los ataques pueden perseguir diferentes objetivos, como dañar los sistemas, tomar el control total de la red u obtener información confidencial, entre otros.

Una vez esclarecidos los conceptos de ciberdelincuente y *hacker* e identificadas las fases de un ataque, resulta esencial comprender los tipos de ataques más comunes para establecer una protección efectiva.

Debemos tener en cuenta que no todos los ciberataques son exactamente iguales, aun cuando se utilicen técnicas y estrategias similares para llevarlos a cabo.

En el siguiente esquema, se detallan los tipos de ataques más comunes:

Inserción de código malicioso	Ataques por ingeniería social	Ataques a las conexiones	Ataques a contraseñas	Otros ataques
Malware	<i>Phishing</i>	MitM	Fuerza bruta	Ataques de día cero o 0-day
Ransomware	<i>Vishing</i>	DoS	Diccionario	
	<i>Smishing</i>	DDoS		
		EDoS		
		Inyección SQL		
		XSS		

Inserción de código malicioso

En este tipo de ataques, los ciberdelincuentes recurren a un tipo de *malware* que les permite **infiltrarse en un dispositivo** sin el conocimiento ni el consentimiento de la víctima.

De este modo, persiguen causar daños a los sistemas, robar información confidencial o emplear el equipo de la víctima para realizar otro tipo de ataques. No obstante, también pueden procurar un beneficio lucrativo, bien secuestrando el equipo del objetivo, bien robando credenciales bancarias o información confidencial para, posteriormente, pedir un rescate; incluso pueden usar el ordenador objetivo para minar criptomonedas y cederlas al atacante.

Normalmente, el *malware* se clasifica en función de su **capacidad de propagación**, pudiendo contemplarse los siguientes tipos:

VIRUS

Un virus informático es un **tipo de malware que se propaga al adjuntarse a otros programas o archivos legítimos**. Su principal objetivo consiste en infectar y dañar archivos, sistemas o dispositivos. Los virus se replican y se propagan al ejecutar el programa o abrir el archivo infectado, y pueden ocasionar diversos problemas, como corrupción de datos, degradación del rendimiento del sistema o robo de información personal.

- **Objetivo principal:** encontrar un vehículo para infectar a otros.
- **Incentivos:** robar información, crear *botnets*, robar dinero, etc.
- **Vectores de infección:** ficheros, correos, *pen drive*, redes sociales, etc.

Si bien existen infinidad de virus informáticos, los más conocidos son:

- **MyDoom.** Se transmite principalmente por correos electrónicos con líneas de asunto como "Error" o "Prueba". Estos correos contienen un fichero que se envía al resto de direcciones de *mail* una vez ejecutado.
- **Sobig.** Considerado el virus más rápido de la historia, ya que dispone de un servidor SMTP (servidor de correo electrónico), lo que le permite propagarse a mayor velocidad.
- **ILOVEYOU.** Programa realizado en VisualBasic que posee la habilidad de enviarse a sí mismo utilizando todo el listado de correos que del usuario o usuaria; además, una vez instalado, deja un gusano capaz de modificar archivos e imágenes.
- **Pikachu.** Similar a *ILOVEYOU* porque también puede enviar correos. Su principal "carisma" reside en que utiliza un Pokemon que, en el momento en que se detecta este virus, era muy conocido, de manera que las personas más jóvenes picaban sin control. En numerosas ocasiones, era capaz de borrar el sistema operativo completo dependiendo de la funcionalidad que se encontrase detrás.



Figura 20. Virus detectado. Fuente: Freepik.com

GUSANOS

Los gusanos informáticos son otro tipo de *malware* que se autorreplica y se propaga de manera autónoma a través de redes informáticas. A diferencia de los virus, no necesitan infectar archivos o programas para propagarse, sino que se aprovechan de **vulnerabilidades de seguridad en sistemas y redes** para replicarse y distribuirse a otros dispositivos. Los gusanos pueden llegar a agotar los recursos de los sistemas afectados, repercutiendo en el rendimiento de la red y facilitando la entrada de otros tipos de *malware*.

- **Objetivo principal:** infectar al siguiente objetivo.
- **Incentivos:** causar daños, diversión, etc.
- **Vectores de infección:** correo, internet en general, ficheros, etc.

TROYANOS

Un troyano o caballo de Troya es un tipo de *malware* que **se presenta como un programa legítimo o útil** para engañar a los usuarios y las usuarias y obtener acceso no autorizado a sus sistemas. A diferencia de los virus y los gusanos, los troyanos **no se replican ni se propagan automáticamente**, sino que recurren al **engaño** para que los usuarios y las usuarias descarguen e instalen el troyano voluntariamente creyendo que es un *software* legítimo. Una vez ejecutado, el troyano permite al atacante acceder al sistema infectado y controlarlo, lo que conduce al robo de información, la instalación de *malware* adicional o la manipulación del sistema.

- **Objetivo principal:** ejecutar funcionalidades ocultas.
- **Incentivos:** robar información, instalar más *malware*, crear *botnets*, etc.
- **Vectores de infección:** usuarios/as.

SPYWARE

Se trata de un tipo de *software* malicioso diseñado para reunir información sobre las actividades de un usuario o una usuaria sin su conocimiento ni su consentimiento. Su principal objetivo consiste en **recopilar información confidencial** como contraseñas, información bancaria, historial de navegación, correos electrónicos o cualquier otro dato personal que, posteriormente, se utilizará con fines maliciosos, entre ellos, el robo de identidad, el fraude financiero o el espionaje. El *spyware* se instala en un sistema de forma oculta y puede monitorear y registrar las actividades del usuario o la usuaria, enviar datos a servidores remotos y afectar el rendimiento del sistema.

- **Objetivo principal:** robar información personal.
- **Incentivos:** teclas pulsadas, información de las cuentas bancarias, etc.
- **Vectores de infección:** virus, gusano o troyano, etc.



Figura 21. *Spyware*. Fuente: Freepik.com

ADWARE

El *adware* es un tipo de *software* que muestra **anuncios publicitarios no deseados en un sistema**, generalmente a modo de ventanas emergentes, *banners* o anuncios insertados en sitios web y aplicaciones. A menudo, se instala sin el consentimiento del usuario junto con otro *software* gratuito que se descarga e instala desde internet. Aunque el *adware* en sí mismo no es tan peligroso como otros tipos de *malware*, sí puede resultar molesto y afectar la experiencia de navegación del usuario o usuaria; además, algunos *adwares* pueden rastrear su actividad y recopilar información sobre sus hábitos de navegación para mostrar anuncios específicos.

- **Objetivo principal:** beneficio económico.
- **Incentivos:** recopilar información, rastrear la actividad de los usuarios y las usuarias.
- **Vectores de infección:** descarga de *software* gratuito, descargas de sitios no confiables, anuncios maliciosos, extensiones del navegador poco fiables.

RANSOMWARE

Se trata de un tipo de *malware* o *software* malicioso que **cifra los archivos o bloquea el acceso a un sistema informático** para, posteriormente, **exigir un rescate** (*ransom*) a cambio de desbloquearlo o descifrar los archivos. Su principal finalidad consiste en extorsionar económicamente a las víctimas, pues los ciberdelincuentes que se encuentran detrás del ataque solicitan un pago, generalmente en criptomonedas, para restaurar el acceso o desbloquear los archivos.

- **Objetivo principal:** de índole económica.
- **Incentivos:** identificar información valiosa y ofrecer una forma de pago segura, normalmente Bitcoin.
- **Vectores de infección:** virus o *criptolockers*.

ROOTKIT

Es un tipo de *malware* que persigue, básicamente, una **escalada de privilegios**, es decir, obtener permisos que el usuario con el que se está trabajando no posee o incluso llegar a ser *root* (máximo administrador del sistema).

- **Objetivo principal:** no ser detectado.
- **Incentivos:** control remoto del dispositivo.
- **Vectores de infección:** gusanos, virus y, a menudo, *exploits* para obtener el acceso a *root*.

BOTS

Se trata de programas de *software* que han sido diseñados para realizar tareas automáticas en un sistema, generalmente a través de la red. Normalmente, se conocen como **botnet**, que es una **red de dispositivos infectados y controlados por un atacante** llamado *botmaster* o "zar de botnets". Estos dispositivos pueden ser computadoras personales, servidores, enrutadores, dispositivos IoT o cualquier otro dispositivo conectado a internet.

- **Objetivo principal:** enviar órdenes dinámicamente a todos los servicios infectados, así como el anonimato.
- **Incentivos:** cualquiera que persiga el *botmaster*.
- **Vectores de infección:** virus, gusanos, troyanos, etc.

Ingeniería social

Una de las técnicas más utilizadas por los ciberdelincuentes es la ingeniería social, que consiste en recurrir a **la manipulación y al engaño** con el fin de **obtener información confidencial o acceso a sistemas**, así como de **llevar a cabo actividades maliciosas**. Por tanto, la ingeniería social se aprovecha de la psicología humana y de la confianza para persuadir a las víctimas y recabar información valiosa sin necesidad de recurrir a métodos técnicos complejos.

Veamos algunos de los principales ataques de ingeniería social:

- **Phishing.** Se trata de uno de los ataques más comunes de ingeniería social. Los ciberdelincuentes envían **correos electrónicos o mensajes fraudulentos que parecen proceder de organizaciones conocidas**, como bancos o servicios en línea. De este modo, tratan de engañar a las personas para que revelen información confidencial, por ejemplo, contraseñas, números de tarjetas de crédito o datos de inicio de sesión.



Figura 22. *Phishing*. Fuente: Freepik.com

- **Spear phishing.** Variante más dirigida del *phishing* donde los atacantes investigan a fondo a la víctima con el objeto de **personalizar el ataque** para que parezca aún más legítimo. En este sentido, utilizan información específica sobre la víctima, como su nombre, cargo o contactos, para ganarse su confianza y obtener acceso a datos sensibles o a sistemas.
- **Vishing.** En este caso, los atacantes llaman a las víctimas haciéndose pasar por **personal de soporte técnico, empleados de una empresa o entidades de confianza** y, por medio del engaño, intentan obtener información confidencial o acceder a sus sistemas mediante la instalación remota de *software* malicioso.
- **Smishing.** Método similar a los anteriores, si bien los atacantes proceden a través de **SMS**.

- **Ingeniería social en redes sociales.** Los ciberdelincuentes utilizan plataformas de redes sociales para reunir información personal sobre las víctimas (fecha de nacimiento, intereses, relaciones...) que, posteriormente, utilizan para crear **ataques más convincentes**. También pueden hacerse pasar por amigos o conocidos para obtener información confidencial o propagar *malware*.
- **Ingeniería social en persona.** Los atacantes pueden manipular a las personas cara a cara fingiendo ser **personal de mantenimiento, repartidores o técnicos** para poder acceder a edificios o sistemas. Asimismo, pueden recurrir a tácticas de persuasión y engaño para obtener información o inducir a las personas a emprender ciertas acciones.

Ataques a las conexiones

Otra de las formas de ataque más comunes se centra en las conexiones y su propósito consiste en **interrumpir y comprometer la comunicación entre dispositivos, redes o sistemas**. Abarca las siguientes variantes:

- **MitM (Man-in-the-Middle).** El atacante se coloca **entre dos partes que están comunicándose, interceptando y modificando potencialmente la información transmitida**. De este modo, el atacante puede leer, alterar o incluso inyectar datos maliciosos en la comunicación sin que las partes involucradas sean conscientes.

Contar con puntos de acceso a la red wifi abiertos o con escasa seguridad, así como con un *software* de navegación anticuado, son aspectos que pueden favorecer este tipo de ataques.

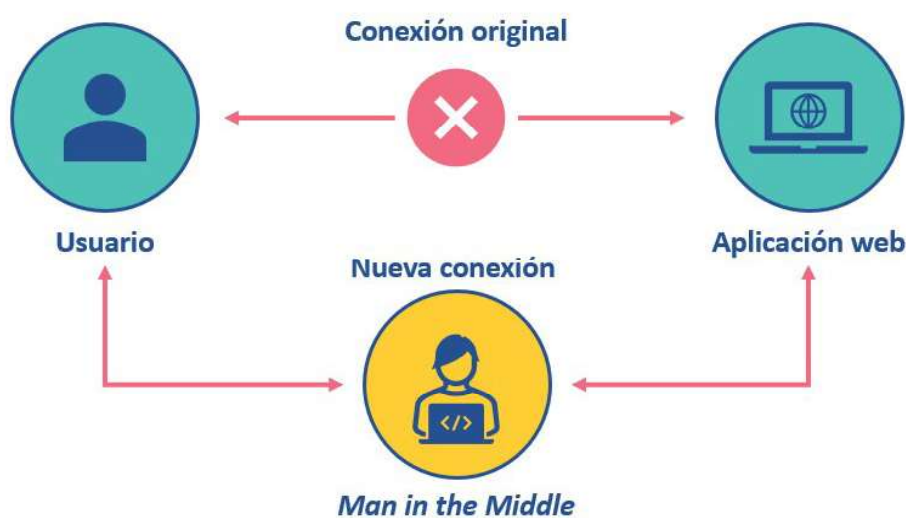


Figura 23. Representación del ataque *Man in the Middle*

- **DoS (Denial of Service).** Ataque cuyo objetivo consiste en **inundar un sistema, red o recurso con una gran cantidad de tráfico o solicitudes**, lo que provoca una sobrecarga y dificulta o impide el acceso legítimo. El principal propósito del ataque de denegación de servicio es interrumpir o limitar el funcionamiento normal del sistema o servicio afectado.
- **DDoS (Distributed Denial of Service).** Variante del ataque DoS donde se recurre a **múltiples dispositivos**, conocidos como **bots** o **zombies**, para que envíen simultáneamente el tráfico malicioso o las solicitudes al objetivo. El ataque DDoS es más poderoso y difícil de mitigar, ya que procede de múltiples fuentes, lo que dificulta la identificación y el bloqueo del tráfico malicioso.

- **EDoS** (*Economic Denial of Sustainability*). Se trata de un nuevo tipo de ataque que afecta al **servicio cloud** y que persigue **agotar los recursos económicos de una organización** al explotar vulnerabilidades en los sistemas de facturación o procesamiento de pagos. De esta forma, se generan costes inesperados o excesivos para la organización, afectando a su sostenibilidad financiera.
- **Inyección SQL** (*SQL Injection*). Tipo de ataque donde se insertan **comandos SQL maliciosos** en las **entradas de un formulario web** o en las **consultas a una base de datos** aprovechando las vulnerabilidades de seguridad del sistema, lo que permite al atacante manipular las consultas y obtener acceso no autorizado a la base de datos, robar información sensible o modificar los datos almacenados.
- **XSS** (*Cross-Site Scripting*). Ataque donde se inserta **código malicioso en un sitio web** que después se ejecuta en el navegador de los usuarios y las usuarias que lo visitan. Su objetivo es robar información, como credenciales de inicio de sesión, o realizar acciones no autorizadas suplantando al usuario o usuaria. Este ataque se aprovecha de las vulnerabilidades en la validación de entrada y la seguridad del sitio web.

Ataques a contraseñas

Los ataques a contraseñas comprenden los diversos métodos y técnicas utilizados por los ciberdelincuentes para **obtener acceso no autorizado a cuentas o sistemas protegidos por contraseñas**.

- **Fuerza bruta**. El atacante prueba todas las combinaciones posibles de contraseñas hasta identificar la correcta. En este sentido, utiliza programas automatizados que verifican diferentes combinaciones a alta velocidad. Este método resulta efectivo si la contraseña es débil o predecible.
- **Ataque de diccionario**. En este caso, el atacante utiliza un diccionario o una lista de palabras comunes, combinaciones de palabras y variaciones para averiguar contraseñas. Tales diccionarios pueden incluir palabras en varios idiomas, nombres comunes, términos relacionados con el usuario o la usuaria, así como información personal.
- **Ataque de fuerza bruta incremental**. Similar al ataque de fuerza bruta, pero en lugar de probar todas las combinaciones posibles desde el principio, comienza con contraseñas más cortas y más sencillas para ir aumentando gradualmente la complejidad hasta identificar la contraseña correcta.

Ataque Zero-Day

Por último, nos referiremos al “ataque de día cero” (*zero day*), una variante que aprovecha una **vulnerabilidad de seguridad desconocida en un sistema, aplicación o software** antes de que el equipo de desarrollo o los proveedores de seguridad hayan generado un parche o una solución para corregirla.

Los atacantes que detectan y explotan una vulnerabilidad de día cero pueden llevar a cabo distintas acciones maliciosas, como obtener acceso no autorizado al sistema, robar información confidencial, instalar *malware* o realizar actividades destructivas.

Detectar y protegerse de este tipo de ataques representa un verdadero reto, ya que las medidas de seguridad tradicionales pueden no resultar efectivas dada la falta de conocimiento sobre la vulnerabilidad. Sin embargo, se aplican técnicas como el análisis de comportamiento, la monitorización del tráfico de red y la implementación

de soluciones de seguridad avanzadas para identificar posibles actividades maliciosas y mitigar el riesgo de este tipo de ataques.

El ataque día cero más famoso es el de **Stuxnet**, un *malware* detectado en **2010** que está considerado uno de los ataques cibernéticos más sofisticados y con mayor impacto de la historia de la ciberseguridad. *Stuxnet* fue concebido para atacar sistemas de control industrial y estaba específicamente dirigido a las instalaciones nucleares de Irán. Así, recurrió a múltiples vulnerabilidades de día cero en los sistemas operativos Windows y en el *software* de control industrial utilizado en las centrifugadoras de enriquecimiento de uranio. Este ataque fue notable porque logró infiltrarse en los sistemas aislados y extremadamente protegidos de las instalaciones nucleares iraníes y causó daños significativos a los equipos sin ser detectado durante un largo período de tiempo. *Stuxnet* había sido diseñado para alterar sutilmente la velocidad de rotación de las centrifugadoras, lo que condujo a su destrucción y repercutió en el programa nuclear de Irán.